

Capstone Project 4 - Threat Intelligence Brief & SOC Recommendations

PIEDMONT MEDICAL GROUP



**MEDICAL
CENTRE**

www.piedmedical.com

Presented by: Paul Leone
Date: October 8, 2025

Overview

Why are we here?



**Focused Overview
of the Threat
Landscape**



**Threat Analysis
Summary
Including MITRE
ATT&CK Mapping
and Risk
Assessment**



**Recommendations
Including
Detection Strategy
Suggestions and
Workflow
Enhancements**



**MEDICAL
CENTRE**

Threat Scenario

UNC5221 Threat to Piedmont Medical Group (PMG)

UNC5221 is a China-nexus espionage threat actor that the PMG team has been actively tracking since October 2023

Targeting Healthcare Sector

UNC5221 focuses on healthcare organizations, exploiting sensitive data and critical systems since 2023.

Exploiting VPN Vulnerabilities

The group uses Ivanti VPN vulnerabilities for initial access, enabling intrusion and persistent threats within networks.

Credential Theft and PHI Exfiltration

UNC5221 attempts to steal credentials and exfiltrate protected health information, posing severe risks to affected organizations.



**MEDICAL
CENTRE**

Threat Analysis

How I Analyzed the Threat

UNC5221 Campaign Review

A detailed review of UNC5221 campaigns from 2023 to 2025 revealed evolving threat techniques and targets.

MITRE ATT&CK Mapping

Threat actor tactics, techniques, and procedures were mapped using the MITRE ATT&CK framework from Initial Access to Exfiltration.

IT Stack and Malware Assessment

focusing on VPNs, edge devices, hybrid Windows/Linux systems, and evaluated malware toolkits targeting PMG's environment.

Healthcare Risk Evaluation

A targeted risk assessment was conducted for healthcare systems to identify vulnerabilities and protect sensitive data.



**MEDICAL
CENTRE**

about
Ivanti

Exploitation – CVE-2025-22457,
CVE-2023-46805, CVE-2024-21887

about
Ivanti

Exploitation – CVE-2025-22457,
CVE-2023-46805, CVE-2024-21887

Mapped kill chain and extended behaviors for UNC521 exploitation

of Ivanti Connect Secure, Policy Secure, and ZTA Gateways. Includes

TRAILBLAZE dropper, BRUSHFIRE backdoor, and SPRAWN ecosystem.

domain

Enterprise

Obfuscated
Files or Information
SVG Smuggling
Stripped Payloads
Steganography
Software Packing
Polymorphic Code
LNK Icon Smuggling
Junk Code Insertion
Indicator
Removal from Tools

platforms

Linux, Windows, Network

legend

0.0

legend

0.0

6.7

10

3.3

6.7

10

Ivanti Exploitation Path

Initial Access	Execution	Persistence	Privilege Escalation	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Wi-Fi Networks	Windows Management Instrumentation	Valid Accounts	Valid Accounts	Unsecured Credentials	Virtualization/Sandbox Evasion	User Account Authentication Material	Video Capture	Web Services	Scheduled Transfer	System Shutdown/Reboot
Valid Accounts	User Execution	Traffic Signaling	Scheduled Task/Job	Steal or Forge Authentication Certificates	Device/Session Cookies	Task Scheduler Content	Capture	Traffic Signaling	Exfiltration Over Web Service	Service Stop
Trusted Relationship	System Services	Software Extensions	Process Injection	OS Credential Dumping	Mobile Machine Discovery	Task Scheduler Content	Capture	Remote Access Tools	Exfiltration Over Physical Medium	Resource Hijacking
Supply Chain Compromise	Software Deployment Tools	Server Software Component	Hijack Execution Flow	Fileless Storage	Embedded Payloads	System Service Discovery	Collection	Policy	Exfiltration Over Physical Medium	Resource Hijacking
Replication Through Removable Media	Shared Modules	Web Shell	Exfiltration	Network Sniffing	Dynamic API Resolution	System Owner/User Discovery	Log	Protocol Tunneling	Exfiltration Over Web Service	System Shutdown/Reboot
Phishing	Scheduled Task/Job	Transport Agent	Exfiltration	Multi-Factor Authentication Request Generation	Compression	System Network Connections Discovery	Log	Non-Standard Port	Exfiltration Over Web Service	Service Stop
Hardware Additions	Native API	Terminal Services DLL	Exfiltration	Multi-Factor Authentication Interception	Compile After Delivery	System Network Configuration Discovery	Log	Non-Application Layer Protocol	Exfiltration Over Physical Medium	Service Stop
External Remote Services	Inter-Process Communication	SOL	Exfiltration	Modify Authentication Process	Command Obfuscation	System Location Discovery	Log	Multi-Stage Channels	Exfiltration Over Other Network Medium	Resource Hijacking
Exploit Public-Facing Application	Input Injection	IIS Components	Exfiltration	Input Capture	Binary Padding	System Information Discovery	Log	Ingress Tool Transfer	Exfiltration Over C2 Channel	Resource Hijacking
Drive-by Compromise	Exploitation for Client Execution	Scheduled Task/Job	Exfiltration	Forge Web Credentials	Modify Registry	Security Software Discovery	Log	Hide Infrastructure	Exfiltration Over Alternative Protocol	Resource Hijacking
Content Injection	Command and Scripting Interpreter	Pre-OS Boot	Exfiltration	Forced Authentication	Indirect Command Execution	Remote System Discovery	Log	Fullback Channels	Exfiltration Over Alternative Protocol	Resource Hijacking
	Windows Command Shell	Power Settings	Exfiltration	Credentials from Password Stores	Indicator Removal	Query Registry	Log	Encrypted Channel	Exfiltration Over Alternative Protocol	Resource Hijacking
	Visual Basic	Office Application Startup	Exfiltration	Brute Force	Impersonation	Permission Groups Discovery	Log	Data Obfuscation	Exfiltration Over Alternative Protocol	Resource Hijacking
	Unix Shell	Modify Registry	Exfiltration	Adversary-in-the-Middle	Impair Defenses	Peripheral Device Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
	Python	Modify Authentication Process	Exfiltration		Spoof Security Alerting	Password Policy Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Safe Mode Boot	Network Sniffing	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Indicator Blocking	Network Share Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Impair Command History Logging	Network Service Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Downgrade Attack	Log Enumeration	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Disable Windows Event Logging	Group Policy Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Disable or Modify Tools	File and Directory Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Disable or Modify System Firewall	Domain Trust Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Disable or Modify Linux Audit System	Device Driver Discovery	Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Hijack Execution Flow		Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Hide Artifacts		Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		File and Directory Permissions Modification		Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Exploitation for Defense Evasion		Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking
			Exfiltration		Execution Guardrails		Log	Data Encoding	Exfiltration Over Alternative Protocol	Resource Hijacking



MEDICAL
CENTRE

MITRE | ATT&CK®

Key Findings

Discovery and Risk Assessment

VPN Compromise and Authentication Bypass

Risk: Exploitation of VPN vulnerabilities could allow attackers to bypass authentication and gain remote access.

Impact: Unauthorized entry into internal systems, exposure of critical infrastructure, and potential foothold for further attacks.

Exposure of Sensitive Data

Risk: Patient records and other sensitive data could be accessed or exfiltrated.

Impact: HIPAA violations, regulatory penalties, breach notifications, lawsuits, and reputational damage to the organization.

Malware and Lateral Movement

Risk: Malware may be deployed to maintain persistence, harvest credentials, and move laterally across the network.

Impact: Expanded compromise beyond the initial entry point, theft of additional data, and disruption of clinical or business operations.

Operational and Compliance Risks

Risk: Attackers could disable logging and monitoring to evade detection.

Impact: Loss of visibility into malicious activity, delayed incident response, overwhelmed SOC analysts, and increased compliance exposure due to incomplete audit trails.



MEDICAL
CENTRE

Recommendations

Strengthening PMG's Defense



Mitigation Strategies

Patch vulnerabilities, keep asset inventory updated, and use network segmentation with multi-factor authentication to reduce risk.



Advanced Threat Detection

Apply Sigma/YARA rules across the security stack to detect anomalies and threats, ensuring robust surveillance of digital assets.



Workflow Enhancement and Automation

Deploy automation and data loss prevention solutions for continuous protection of sensitive information and streamlined incident response.



MEDICAL
CENTRE



SOC Detection Strategy

Detection Rules and Integrations

Multi-Platform Detection Logic

Detection rules operate across several platforms, enabling layered and comprehensive security coverage against threats.

System Integrations

Integrations include endpoint protection, authentication monitoring, firewall filtering, file integrity monitoring, and domain tracking.

Advanced Rule Applications

YARA rules are used for deep scanning, while Suricata IPS blocks exploits and shell droppers in real time.

YARA → malware ID, endpoint detection and forensic triage → BRUSHFIRE, TRAILBLAZE, SPAWN

Sigma → Enhance log-based detection across multiple platforms

SentinelOne → Deep Visibility for in memory payloads

CrowdSec → Detection Scenarios for auth bypass, command injection, TRAILBLAZE

Firewall filters → blocklists via remediation service (CrowdSec)

FIM → monitor /home/bin/web, /tmp/, /var/log/

Workflow Enhancements

Correlation and Response

Advanced Threat Detection

Utilizing Sigma with Splunk allows detection of webshell activity, exploit chains, and correlating Suricata rules with post-exploitation incidents.

SOAR Integration and Automation

Integrating SOAR automates essential SOC actions, including system isolation, incident enrichment, and alert notifications for faster response.

Multi-Platform Security Coverage

Layering additional detection and correlation rules across the stack ensures end-to-end visibility, closes detection gaps, and strengthens the overall security posture.



**MEDICAL
CENTRE**

Workflow Enhancements

Optimizing Existing Tools

SentinelOne Singularity Endpoint: Device inventory, Ranger discovery, STAR custom rules

- Automatically discover endpoints and perform passive network discovery via Device Inventory and Ranger.
- Storyline (STAR) correlation logic to flag suspicious behaviors.

Threat Intel Integration: CISA, Health ISAC, commercial feeds into STAR, CrowdSec, Splunk SOAR and DLP

- Ingest threat intel feeds and correlate to alerting via Splunk and SentinelOne Singularity Endpoint
- Apply threat intel to outbound DLP file scanning

Passive DNS/Proxy: detect tunneling, proxy evasion, outbound C2

- DNS tunneling or repeated outbound attempt correlation with Splunk
- Outbound traffic inspection correlated to DLP for sensitive data exfiltration.



**MEDICAL
CENTRE**

Workflow Enhancements

New Platform and Technology Acquisitions



CrowdSec Security Enhancement

CrowdSec improves security through real-time, behavioral detection providing:

- Automatic blocking of known malicious IPs,
- Log integration,
- Sharing intelligence within the community.



Splunk SOAR Automation

Splunk SOAR streamlines incident response by automating playbooks, correlating intelligence, and supporting comprehensive case management.

- Enables rapid containment,
- reduces SOC fatigue and
- supports compliance reporting for PHI/PII incidents



Advanced DLP Integration

Advanced DLP tools inspect content, enforce data security policies, support YARA, and integrate with SOAR for holistic protection.

- Prevents PHI/PII exfiltration,
- adds compensating controls,
- supports forensic triage



**MEDICAL
CENTRE**



Firewall / Rules / LAN

Floating

Tailscale

WAN

LAN

SYNC

LA

VPN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✗	0/1.82 MiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	⚙️
☑️	0/32 KiB	IPv4 *	*	*	pfB_PRI1_v4						📌 ✎️ 🗑️
☑️	0/0 B	IPv4 *	*	*	crowdsec6_blacklists						📌 ✎️ 🗑️
☑️	0/660 B	IPv4 *	*	*	crowdsec_blacklists						📌 ✎️ 🗑️
192.168.100.0/24 rules											
☑️	0/75.54 MiB	IPv4 *	192.168.100.15	*	192.168.1.3						📌 ✎️ 🗑️ ✖️
☑️	0/0 B	IPv4 *	192.168.100.15	*	192.168.1.247	*	*	none			📌 ✎️ 🗑️ ✖️

Alias details

Value	Description
45.9.148.120	UNC5221 Reported in Ivanti exploitation campaigns
103.27.186.11	APT41 (China) Used in multiple supply chain intrusions
185.220.101.26	Sandworm (Russia) Linked to VPNFilter and ICS targeting
91.212.124.159	Turla (Russia) Known C2 infrastructure for watering hole ops
203.131.222.10	Lazarus Group (North Korea) Used in financial and healthcare targeting
82.118.21.1	APT28 (Russia) Associated with phishing and credential theft
192.42.116.41	Mustang Panda (China) Used in malware delivery and C2
104.244.75.98	APT10 (China) Cloudhopper campaign infrastructure
176.123.2.50	Gamaredon (Russia) Used in phishing and remote access campaigns



CENTRE

Thank You / Q&A



**MEDICAL
CENTRE**

www.piedmedical.com

Presented by: Paul Leone
Date: October 8, 2025